INSPECCO × KRIPTARIUM

Safety 4.0 Bootcamp

Laboratuvar Föyleri — Genel Sürüm · Şişeleme Hattı

Tüm laboratuvarlar gün boyu gelişen tek bir örnek makine — jenerik şişeleme hattı — üzerinde işlenir.

LAB 1 · Safety Architecture	Çıktı: Safety Function Map
LAB 2 · IEC 62443 Mini Workshop	Çıktı: Zone / Conduit Diagram
LAB 3 · Threat & Risk + Risk Matrix	Çıktı: Risk Register
LAB 4 · Secure Remote Access	Çıktı: Secure Architecture
LAB 5 · SBOM / CVE / Patch	Çıktı: Vulnerability Decision
LAB 6 · CRA Incident Simulation	Çıktı: Incident Workflow
LAB 7 · AI Safety Challenge	Çıktı: AI Fail-Safe Decision

Bu föyler bir eğitim çıktısıdır; resmî denetim, uygunluk değerlendirmesi veya belgelendirme değildir ve CE/mevzuat uygunluğu garantisi vermez. Doldurduğunuz föyler gün sonunda Machine Starter Pack'inizi oluşturur ve Safety 4.0 Workspace'te yaşamaya devam eder.

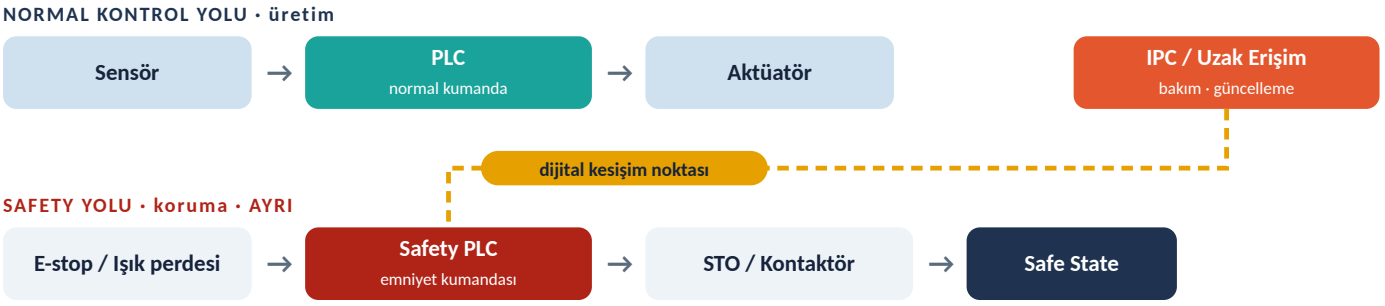
LABORATUVAR 1 · GENEL SÜRÜM · Şişeleme Hattı

Safety Architecture

Çıktı: Safety Function Map

Ad Soyad: Gezgin Altay | Grup | Tarih

Atalay RK kenar bantlama makinesi; ön frezeleme, yapıştırma, köşe yuvarlama ve kazıma ünitelerine sahiptir. Freze/kazıma takımları ve hareketli baskı-besleme noktaları tehlike oluşturur. Emniyet elemanları ve güvenlik zinciri elektrik şemasından doğrulanmalıdır.



Görev — sırayla cevaplayın

1. Bu makinede tehlike nedir? İnsan neyden zarar görür?

   Temas/kesilme: freze ve kazıma takımları; sıkışma: baskı makaraları ve besleme noktaları. Yapıştırma ünitesi sıcaksa yanık riski de vardır.

2. Safety function (emniyet fonksiyonu) hangisidir?

   Tehlikeli bölgeye erişim veya koruyucu açılması algılandığında freze, kazıma, köşe yuvarlama ve besleme hareketlerini güvenli biçimde durdurmak.

3. Safety-related control system nerede? Şemada işaretleyin.

   Koruyucu/erişim sensörleri ve acil stop → safety rölesi/PLC → STO veya kontaktörler. Gerçek bileşenler elektrik şemasından doğrulanmalıdır.

4. Normal PLC ile Safety PLC farkı nedir?

   Normal PLC üretim ve proses kontrolünü yapar; Safety PLC/röle güvenlik girişlerini izler ve tehlikeli hareketi güvenli biçimde durdurur.

5. PLr / SIL neden var? Bu fonksiyon için neden önemli?

   PLr/SIL riskin gerektirdiği emniyet performansını belirler; ağır yaralanma riski olan kesme, frezeleme ve sıkışma tehlikelerinde önemlidir.

6. Safe state (güvenli durum) nedir?

   Tehlikeli ünitelerin durması ve enerjinin güvenli kesilmesi; yeniden başlatma ancak tehlike giderilip kontrollü onay verildiğinde yapılır.

7. Safety function hangi dijital bağımlılıklara sahip?

   PLC yazılımı/parametreleri, sürücü ayarları, sensörler, HMI, servis bağlantısı ve varsa safety kontrolörü konfigürasyonu.

8. Siber müdahale hangi noktadan bu fonksiyonu bozar?

   Servis/mühendislik portu, HMI veya PLC programlama bağlantısı. Yetkisiz değişiklik safety zincirine erişebiliyorsa güvenli duruş bozulabilir.

Bu föyün çıktısı **Safety Function Map** → Evidence Pack **EP 03 Safety Functions** başlığına oturur.

LABORATUVAR 2 · GENEL SÜRÜM · Şişeleme Hattı

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad: Gezgin Altay | Grup: | Tarih:

Kavram: Zone = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi

PLC · HMI · Robot kontrolörü · **Safety PLC** · SCADA istemcisi · Mühendislik istasyonu · Uzak servis erişimi · Ofis ağı (ERP/e-posta)

1 Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

Üretim bölgesi: PLC, HMI, sürücüler ve proses sensörleri. Emniyet bölgesi: safety rölesi/PLC, koruyucu şalterleri ve acil stop. Bakım bölgesi: mühendislik istasyonu ve servis portları. Kurumsal bölge: ofis ağı. Varsa uzaktan servis ayrı DMZ bölgesinde tutulur.

2 Safety PLC'yi hangi bölgeye koydunuz — neden?

Safety PLC/röle ayrı ve yüksek kritiklikte emniyet bölgesinde olmalı; ofis ağına veya internete doğrudan yönlendirilmemelidir. Uzak servis erişimi emniyet bölgesinde bulunmamalıdır.

3 Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

Üretim↔bakım, üretim↔emniyet ve ofis↔bakım geçişleri kontrollü conduit olmalı. Yalnız gerekli port/protokoller açılmalı; kimlik doğrulama, kayıt, izleme ve ağ segmentasyonu uygulanmalıdır.

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	Jump server; kontrollü ara nokta
Tünel?	Açık / VPN	VPN; şifreli tünel
Kimlik?	Parola / MFA	MFA; ek kimlik doğrulama
Hesap?	Paylaşılan / Kişisel	Kişisel hesap; en az yetki
Kayıt?	Yok / Tam oturum kaydı	Tam oturum kaydı; izlenebilirlik
Zamanlama?	Sürekli açık / Varsayılan kapalı	Varsayılan kapalı; süreli açılır

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.

LABORATUVAR 3 · GENEL SÜRÜM · Şişeleme Hattı

Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad: Gezgin Altay | Grup: | Tarih:

Kavram: Senaryo beş parçadır: **kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç**. Skor = L × S × E (her biri 1–3). **Kural:** S=3 ise skor düşük olsa bile senaryo öne alınır — insana zarar görünür kalır.

Görev — üç senaryo kurun ve puanlayın

Senaryo (kim→kapı→zincir→fiziksel sonuç)	L	S	E	Skor	Öncelik
Yetkisiz servis kullanıcısı → servis portu → PLC parametresini değiştirir → koruma/çalışma sırası bozulur, el yaralanması	L:2	S:3	E:2	Skor:12	Yüksek
Zararlı USB → mühendislik istasyonu → değiştirilmiş PLC projesi yüklenir → beklenmeyen hareket, yaralanma	L:2	S:3	E:2	Skor:12	Yüksek
HMI/kurumsal ağ saldırısı → zayıf parola/açık port → üretim komutu değişir → sıkışma/temas riski	L:2	S:3	E:1	Skor:6	S=3 öncelikli

Kritik 18–27 | Yüksek 9–17 | Orta 4–8 | Düşük 1–3

1. En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?

   En yüksek öncelik: yetkisiz PLC değişikliği; koruma davranışını etkileyebilir ve doğrudan ağır fiziksel yaralanmaya yol açabilir.

2. S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?

   Üçüncü senaryoda skor 6 olsa da S=3'tür. Düşük kabul edilmemeli; ayrı işaretlenmeli, güvenlik sorumlusu tarafından gözden geçirilmelidir.

Altın kural: Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir — bir adım daha gidin: bu, hattaki insana ne yapar?

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.

LABORATUVAR 4 · GENEL SÜRÜM · Şişeleme Hattı

Secure Remote Access

Çıktı: Secure Architecture

Ad Soyad: Gezgin Altay | Grup: | Tarih:

Kavram: İki katman, ikisi de şart: **erişim güvenliği** (girişi zorlaştır: ara nokta, VPN, MFA, kişisel hesap, kayıt, varsayılan kapalı) + **emniyet bağımsızlığı** (girse bile insan korunur).

Görev A — mevcut → hedef

MEVCUT (çizin/yazın)

Mevcut: PLC/HMI servis portlarına bakım erişimi gerekir. Bağlantının internete açık olduğu bilgisi verilmemiştir; doğrudan internet erişimi varsayılmamalıdır. Kontrolsüz USB ve ortak hesaplar risk oluşturur.

HEDEF (beş ilkeyle yeniden tasarlayın)

Hedef: Jump server, VPN, MFA, kişiye özel ve en az yetkili hesap, tam oturum kaydı, varsayılan kapalı/süreli erişim. Emniyet ağına doğrudan uzaktan erişim verilmemelidir.

Görev B — functional safety köprüsü

1. Saldırgan tüm önlemlere rağmen içeri girerse: emniyet fonksiyonu etkilenir mi? Neden?

   Evet. Saldırgan PLC programını/parametrelerini veya güvenlik ayarlarını değiştirebilirse tehlikeli hareket durmayabilir. Erişim güvenliği yanında emniyet zinciri bağımsız ve doğrulanmış olmalıdır.

2. Emniyet fonksiyonunun kontrol sisteminden bağımsız çalışması için GEREKSİNİMİ yazın (çözümü değil).

   Gereksinim: Uzak bakım veya normal PLC/HMI ağı ele geçirilse bile emniyet fonksiyonu devre dışı bırakılamamalı, değiştirilememeli ve güvenli duruş engellenememelidir.

Tarafsızlık notu: Bu föy çözüm tasarlatmaz; gereksinimi tanımlatır. Tasarım kararı firmanızındır.

Bu föyün çıktısı **Secure Architecture** → Evidence Pack **EP 02 + EP 06** başlığına oturur.

LABORATUVAR 5 · GENEL SÜRÜM · Şişeleme Hattı

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad: Gezgin Altay | Grup: | Tarih:

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	Atalay RK PLC/üretim kontrol yazılımı bileşeni (örnek; gerçek SBOM doğrulanmalı)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

   Kesin karar verilemez: bileşenin makinede bulunması, sürümün 2.4 olması ve açığın erişilebilir olması birlikte doğrulanmalı. Üretici SBOM/CVE bildirimi istenmelidir.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

   Plansız şekilde hemen durdurulmaz. Önce etki ve erişilebilirlik doğrulanır; açık emniyet fonksiyonunu veya tehlikeli hareketi etkileyebiliyorsa makine güvenli duruşa alınır.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

   Önce üretim dışı test ortamında veya aynı PLC/sürücü/HMI donanımının yedek test düzeneğinde denenir. Fonksiyon ve emniyet doğrulaması yapılmadan uygulanmaz.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

   Yama PLC, sürücü, safety kontrolörü veya güvenlik haberleşmesini etkiliyorsa safety validation tekrarlanır. Üretici notu, etki analizi ve test kayıtları incelenir.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

   Yama yoksa ilgili port/hizmet kapatılır, ağ segmentasyonu ve erişim listesi sıkılaştırılır, uzaktan erişim kapatılır/süreli yapılır; izleme artırılır ve üretici düzeltmesi beklenir.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.

LABORATUVAR 6 · GENEL SÜRÜM · Şişeleme Hattı

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad: Gezgin Altay | Grup: | Tarih:

Senaryo: Saat 10:15. Atalay RK makinesinin bakım/servis hesabında yetkisiz erişim fark edildi. PLC parametreleri veya koruma ayarları değişmiş olabilir. Makine çalışıyor; vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. **10:15 — ilk 15 dk:** Kimi ararsınız? İlk üç eyleminiz?

   Bakım sorumlusu, otomasyon mühendisi ve iş güvenliği/üretim sorumlusunu ararım. 1) Tehlikeli bölgeyi boşaltıp makineyi güvenli duruşa alırım. 2) Yetkisiz bağlantıyı izole ederim. 3) Logları ve mevcut konfigürasyonu korurum.

2. **İlk 2 saat:** Emniyet güvende mi? Neyi korursunuz (kanıt!)? Hangi hesap kapatılır?

   Makineyi güvenli duruşta tutar, koruyucuları ve acil stop zincirini yetkili kişiyle doğrularım. PLC/safety konfigürasyonunu onaylı yedekle karşılaştırırım. Servis hesabını kapatır, logları silmeden kopyalarım.

3. **24 saat — CRA erken uyarı:** Hangi bilgi hazır olmalı?

   Makine/ürün kimliği, tespit zamanı, etkilenen bileşen ve sürüm, olayın niteliği, bilinen fiziksel/operasyonel etki, geçici önlemler ve iletişim kişisi hazır olmalıdır.

4. **72 saat — CRA bildirim:** Kök neden, etki, önlem — kim ne yapıyor?

   Teknik ekip kök nedeni ve erişim yolunu belirler; otomasyon ekibi etkilenen PLC/HMI/sürücü ve parametreleri inceler; sorumlu ekip etki ve bildirim sürecini yürütür. Üretim emniyet onayı olmadan başlamaz.

5. **14 gün — son rapor:** Hangi loglar/kayıtlar korunmuş olmalı?

   VPN/firewall ve servis erişim logları, kullanıcı oturumları, PLC/HMI proje ve parametre yedekleri, safety konfigürasyonu, alarm geçmişi, USB kayıtları ve müdahale tutanakları korunur.

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.

LABORATUVAR 7 · GENEL SÜRÜM · Şişeleme Hattı

AI Safety Challenge

Çıktı: AI Fail-Safe Decision

Ad Soyad: Gezgin Altay | Grup: | Tarih:

Kavram — Prediction ≠ Safety: Yapay zekâ bir karar üretir; güvenliği garanti eden mimari YZ'nin **dışında** tanımlanmalıdır.
Araçlar: fail-safe · human override · monitoring · confidence threshold · fallback.

Kamera → YZ Modeli → OK / RED → Parametre → Robot

Görev — üç başarısızlıkta güvenli davranış

1. **Model yanlış sınıflandırdı:** Kusurlu parçaya OK verdi. Sistem ne yapmalı? İkinci kontrol / insan onayı var mı?

İkinci kontrol/insan onayı uygulanır. Kusurlu parçaya yanlış OK verilirse parça güvenli ret yoluna yönlendirilir; belirsizlikte hat durur. Human override ve fail-safe kullanılır.

2. **Girdi manipüle edildi:** Kamera verisi bozuk/sahte. Nasıl fark edilir? Şüpheli girdide ne yapılır?

Kamera verisi bütünlük, format, zaman damgası ve anomali kontrollerinden geçirilir. Şüpheli görüntüde karar geçersiz sayılır; parça reddedilir veya hat kontrollü durur, operatöre alarm verilir.

3. **Confidence düştü:** Model "emin değilim" diyor. Eşik ne olmalı? Altında: dur / insana sor / fallback?

Confidence eşiği doğrulama verisiyle belirlenir; 0,90 yalnız başlangıç önerisidir, kesin değer değildir. Eşik altında otomatik OK verilmez; insan kontrolü veya güvenli ret uygulanır.

Karar tablosu — AI Fail-Safe Decision

Başarısızlık	Tanımladığınız güvenli davranış (hangi kavramla?)
Model yanlış sınıflandırdı	Fail-safe + ikinci kontrol + insan onayı; kusurlu parçaya OK verme.
Girdi manipüle edildi	Girdi doğrulama + monitoring; şüpheli görüntüde fallback/hat duruşu.
Confidence düştü	Confidence threshold; eşik altında insan kontrolü veya güvenli ret.

Bu föyün çıktısı **AI Fail-Safe Decision** → Evidence Pack **EP 03 + EP 15** başlığına oturur.